Análisis de informes de incidentes

Resumen	La red interna de la organización sufrió un ataque de denegación de servicio (DoS) que la mantuvo comprometida durante aproximadamente dos horas. Los servicios de red dejaron de responder debido a una avalancha de paquetes ICMP entrantes (ping flood), lo que impidió que el tráfico interno legítimo accediera a los recursos de la red. La investigación determinó que un actor malicioso externo envió la inundación de pings ICMP a través de un cortafuegos sin configurar; esa vulnerabilidad le permitió saturar la red. El equipo de gestión de incidentes respondió bloqueando los paquetes ICMP entrantes, poniendo fuera de línea los servicios no críticos y restableciendo los servicios críticos. El impacto fue sobre la disponibilidad: indisponibilidad temporal de los servicios de red internos, sin pérdida de datos reportada.
Identificar	Tipo de ataque: denegación de servicio (DoS) mediante inundación de paquetes ICMP (ping flood). Sistemas afectados: los servicios de red internos y todos los recursos de la red interna, inaccesibles durante unas dos horas. Origen: un actor malicioso externo que envió el tráfico ICMP a través de internet. Causa/vulnerabilidad: un cortafuegos sin configurar que no limitaba ni filtraba los paquetes ICMP entrantes, lo que permitió saturar la red. Se auditan las redes internas, sistemas, dispositivos y privilegios de acceso para detectar otras brechas similares (por ejemplo, reglas de cortafuegos ausentes).
Proteger	Medidas aplicadas y plan de protección: (1) nueva regla de cortafuegos para limitar la tasa (rate limiting) de los paquetes ICMP entrantes; (2) verificación de la dirección IP de origen en el cortafuegos para detectar IP falsificadas (anti-spoofing) en los paquetes ICMP; (3) endurecimiento de la configuración del cortafuegos; (4) principio de mínimo privilegio y revisión de los accesos; (5) capacitación del personal para reconocer y reportar actividad anómala. El objetivo es reducir la superficie de ataque y evitar que una inundación ICMP vuelva a saturar la red.
Detectar	Métodos de detección: (1) software de supervisión de red para identificar patrones de tráfico anómalos, como picos de ICMP; (2) sistema IDS/IPS para

	filtrar el tráfico ICMP con características sospechosas y alertar o bloquear en tiempo real; (3) análisis de los registros del cortafuegos, idealmente centralizados en un SIEM, para detectar ICMP externo entrante desde direcciones IP no confiables que intenten atravesar el cortafuegos. Se supervisa el tráfico de forma continua y se distingue entre usuarios autorizados y no autorizados.
Responder	Plan de respuesta para incidentes similares. Contención: bloquear los paquetes ICMP entrantes y aislar o poner fuera de línea los servicios no críticos afectados. Neutralización: aplicar reglas del cortafuegos (rate limiting y bloqueo de la IP de origen) y el filtrado del IDS/IPS. Análisis: usar los registros del cortafuegos, las capturas de tráfico y las alertas del IDS/IPS para determinar el origen, el volumen y el método del ataque. Comunicación: informar al equipo de TI y a la gerencia según los procedimientos. Mejora: actualizar las reglas y los procedimientos tras el incidente.
Recuperar	Plan de recuperación: restablecer primero los servicios de red críticos y, luego, volver a poner en línea los servicios no críticos una vez verificado que el tráfico malicioso cesó, confirmando que la red interna opera con normalidad. Como el impacto fue sobre la disponibilidad y no se reportó pérdida de datos, no se requirió restauración desde copias de seguridad; de haber datos afectados, se restaurarían desde el último respaldo. Mejoras: documentar el incidente, revisar periódicamente las reglas del cortafuegos y actualizar el plan de recuperación para gestionar mejor futuros incidentes.

Reflexiones/Notas: